

PLAN DE RESPUESTA A INCIDENTES Y RECUPERACIÓN ANTE DESASTRES

Cybersecurity DR — Versión 3.1 | Julio 2026

1. DEFINICIONES CLAVE

- Incidente de seguridad:** Cualquier evento que comprometa o intente comprometer la confidencialidad, integridad o disponibilidad de los activos de información.
- Desastre:** Evento que interrumpe operaciones críticas a gran escala: incendio, inundación, ciberataque masivo (ransomware), falla de proveedor cloud, etc.
- RTO (Recovery Time Objective):** Tiempo máximo de inactividad permitido para un sistema o proceso después de un desastre.
- RPO (Recovery Point Objective):** Pérdida máxima de datos aceptable, medida en tiempo.

2. OBJETIVOS DE RECUPERACIÓN (RTO / RPO)

Sistema / Proceso	RTO	RPO	Estrategia
Servicios críticos (SOC, monitoreo)	1 hora	15 minutos	Replicación síncrona + failover automático
Bases de datos de clientes	4 horas	1 hora	Backups incrementales cada hora; réplica en zona secundaria
Correo corporativo y colaboración	8 horas	4 horas	SaaS redundante (Microsoft 365 con geo-replicación)
Sistemas de desarrollo	24 horas	8 horas	Backups diarios; infraestructura como código (IaC)
Archivos históricos y logs	72 horas	24 horas	Almacenamiento en frío (Glacier / Archive Storage)

Ambos valores (RTO y RPO) se definen en el **Análisis de Impacto al Negocio (BIA)** y se revisan semestralmente.

3. ROLES Y RESPONSABILIDADES

Rol	Responsabilidad
CSIRT (Computer Security Incident Response Team)	Coordinación general, análisis forense, contención y erradicación.
Líder de Comunicaciones	Comunicación interna, clientes, reguladores y medios.

Table 2 – continued

Rol	Responsabilidad
Equipo Legal	Cumplimiento normativo, notificaciones a autoridades, gestión de evidencias.
Infraestructura /	Restauración de servicios, validación de backups, reconfiguración de red.
DevOps	
RRHH	Bienestar del equipo, gestión de turnos extendidos durante crisis.

4. FASES DE RESPUESTA A INCIDENTES

FASE 1: Detección y Análisis

- Alertas provenientes de SIEM (Splunk / Sentinel), IDS/IPS, reportes de usuarios o threat intelligence.
- Triage inicial: clasificación por severidad (Baja, Media, Alta, Crítica).
- Cadena de custodia: preservación de logs, imágenes de disco y tráfico de red.

FASE 2: Contención

- **Contención a corto plazo:** Aislamiento inmediato de sistemas afectados (desconexión de red, bloqueo de cuentas comprometidas).
- **Contención a largo plazo:** Segmentación de red adicional, cambio de credenciales masivo, aplicación de parches de emergencia.

FASE 3: Erradicación

- Eliminación de malware, backdoors y cuentas no autorizadas.
- Reinstalación limpia de sistemas operativos si la integridad es dudosa.
- Validación con herramientas forenses antes de reincorporar equipos a la red.

FASE 4: Recuperación

- Restauración desde backups verificados (prueba de restauración mensual).
- Monitoreo intensificado durante 72 horas posteriores.
- Validación funcional con usuarios clave antes de declarar “operación normal”.

FASE 5: Lecciones Aprendidas

- Post-mortem obligatorio dentro de 5 días hábiles.
- Actualización de controles, playbooks y políticas según hallazgos.

5. PROTOCOLO ESPECÍFICO: ATAQUE DE RANSOMWARE

1. **Aislar inmediatamente** los sistemas afectados para evitar la propagación lateral (desconectar Wi-Fi, cables de red, bloquear puertos en switch).
2. **Notificar al CSIRT** y al equipo de respuesta a incidentes dentro de los primeros 15 minutos.
3. **NO PAGAR EL RESCATE.** La política de Cybersecurity DR prohíbe el pago de rescates por ransomware.

- 4. **Iniciar el proceso de recuperación** desde copias de seguridad limpias (air-gapped backups).
- 5. **Reportar el incidente** a las autoridades competentes (Policía Cibernética, CERT nacional, etc.) según el procedimiento establecido en la Política de Seguridad.
- 6. **Conservar evidencias** para análisis forense: imágenes de discos encriptados, logs, muestras del malware.
- 7. **Comunicar a clientes afectados** dentro de las 72 horas si se vio comprometida información personal (cumplimiento normativo).

6. ESTRATEGIA DE BACKUPS Y RECUPERACIÓN

- **Regla 3-2-1:** 3 copias de los datos, en 2 medios diferentes, 1 fuera del sitio (off-site / air-gapped).
- **Frecuencia:**
 - Críticos: cada 15 minutos (replicación continua).
 - Importantes: diario.
 - Históricos: semanal.
- **Pruebas:** Simulacro de recuperación completa (DR Drill) cada 3 meses. El resultado se documenta y se presenta a la dirección.

7. COMUNICACIÓN EN CRISIS

- **Interna:** Canal dedicado en Microsoft Teams / Slack; actualizaciones cada 2 horas durante incidentes críticos.
- **Clientes:** Plantilla pre-aprobada de correo de notificación; SLA de comunicación inicial: 4 horas para incidentes que afecten datos de clientes.
- **Reguladores:** Notificación a autoridades de protección de datos dentro de los plazos legales establecidos (ej. 72 horas para GDPR).

8. CONTACTOS DE EMERGENCIA

Entidad	Contacto	Disponibilidad
CSIRT Líder	csirt@cybersecuritydr.com	24/7
SOC Gestionado	+1-800-SOC-DR24	24/7
Proveedor Cloud (OCI)	Soporte Enterprise	24/7
Aseguradora Cibernética	broker@cyberinsure.com	Horario comercial
Forense Externo	forense@partner-dfir.com	Bajo contrato 24/7

Documento aprobado por: Chief Information Security Officer (CISO)
Fecha: 15/07/2026
Próxima revisión: 15/01/2027